

## 1. Die drei Haupt-Schutzziele (CIA-Triade)

Die IT-Sicherheit basiert auf drei grundlegenden Säulen:

- **Vertraulichkeit (Confidentiality):** Daten dürfen nur von autorisierten Personen gelesen oder verarbeitet werden.
- **Integrität (Integrity):** Daten müssen korrekt, vollständig und vor unbefugter oder unbeabsichtigter Veränderung geschützt sein.
- **Verfügbarkeit (Availability):** IT-Systeme und Daten müssen für die Berechtigten zum geplanten Zeitpunkt nutzbar sein.

## 2. Spezifische Anforderungen (Beispiel Datenbanken)

Zusätzlich zu den Schutzzielen gibt es oft konkrete administrative Anforderungen:

- **Rechtssicherheit:** Einhaltung von Gesetzen zum Schutz von Daten (z. B. DSGVO).
- **Nachvollziehbarkeit:** Änderungen an Daten müssen lückenlos dokumentiert sein.
- **Prävention:** Unberechtigte Zugriffe müssen aktiv verhindert werden.

## 3. Technische und organisatorische Maßnahmen (TOM)

Maßnahmen werden oft nach dem Ort ihrer Wirkung unterschieden:

| Bereich                      | Maßnahme                                     | Zweck                                                                   |
|------------------------------|----------------------------------------------|-------------------------------------------------------------------------|
| <b>Zutrittskontrolle</b>     | Alarmanlagen, RFID-Karten, Besucheranmeldung | Verhindert physischen Zugang zum Gebäude.                               |
| <b>Zugangskontrolle</b>      | Passwortregeln, Biometrische Merkmale        | Verhindert die Nutzung von IT-Systemen durch Unbefugte.                 |
| <b>Zugriffskontrolle</b>     | Berechtigungskonzepte, Benutzerprofile       | Regelt, wer welche Daten innerhalb eines Systems sehen/bearbeiten darf. |
| <b>Datenträgersicherheit</b> | Verschlüsselung, fachgerechte Entsorgung     | Schützt Daten bei Verlust oder Entsorgung der Hardware.                 |

## 4. Netzwerksicherheit

- **Firewalls:** Einsatz von **Stateful Packet Inspection (SPI)** zur Überwachung des Verbindungsstatus oder **Next Generation Firewalls (NGFW)** für tieferegehende Analysen wie SSL/TLS-Inspection.
- **Verschlüsselung & VPN:** Sicherung von Verbindungen mittels IPsec oder SSL/TLS. TLS 1.3 bietet hierbei Vorteile wie **Forward Secrecy**.
- **VLANs:** Segmentierung des Netzwerks, um die Ausbreitung von Angriffen zu begrenzen und Broadcast-Last zu reduzieren.
- **DMZ (Demilitarisierte Zone):** Ein abgeschotteter Netzbereich für öffentlich erreichbare Server (z. B. Webserver), um das interne Netz zu schützen.

## 5. Strategien und Prinzipien

- **Least-Privilege-Prinzip:** Nutzer erhalten nur die minimal notwendigen Rechte für ihre Aufgaben.
- **Zero-Trust-Prinzip:** Jeder Zugriff innerhalb oder außerhalb des Netzes muss verifiziert werden; keinem Gerät wird blind vertraut.
- **System-Härtung (Hardening):** Deaktivierung nicht benötigter Dienste, Ändern von Standardpasswörtern und regelmäßiges Patch-Management.
- **Sicherer Boot-Vorgang:** Nutzung von TPM 2.0 und **Secure Boot**, um das Starten manipulierter Software zu verhindern.

## 6. Datensicherung und Ausfallsicherheit

- **3-2-1-Regel:** Drei Kopien der Daten auf zwei verschiedenen Medien, davon eine außer Haus.
- **Air Gap:** Physische Trennung der Sicherungsmedien vom Netzwerk (z. B. LTO-Bänder), um Schutz vor Ransomware zu bieten.
- **RAID-Systeme:** Erhöhung der Verfügbarkeit durch Redundanz (z. B. RAID 6 bietet Schutz bei gleichzeitigem Ausfall von zwei Platten).
- **USV (Unterbrechungsfreie Stromversorgung):** Überbrückung von Stromausfällen, um Systeme kontrolliert herunterzufahren oder weiterzubetreiben.

## 7. Mitarbeitersensibilisierung

Schulungen sind essenziell, um Gefahren wie **Phishing** (betrügerische E-Mails), **Trojaner** oder **Viren** zu erkennen. Anzeichen für Phishing können z. B. unbekannte Absender, dringende Handlungsaufforderungen oder fehlerhafte Hyperlinks sein.